

Penetration Testing a pfSense Firewall (3e)

Network Security, Firewalls, and VPNs, Third Edition - Lab 10

Student:
Christopher Phan

Email:
cphan@udallas.edu

Time on Task:
7 hours, 21 minutes

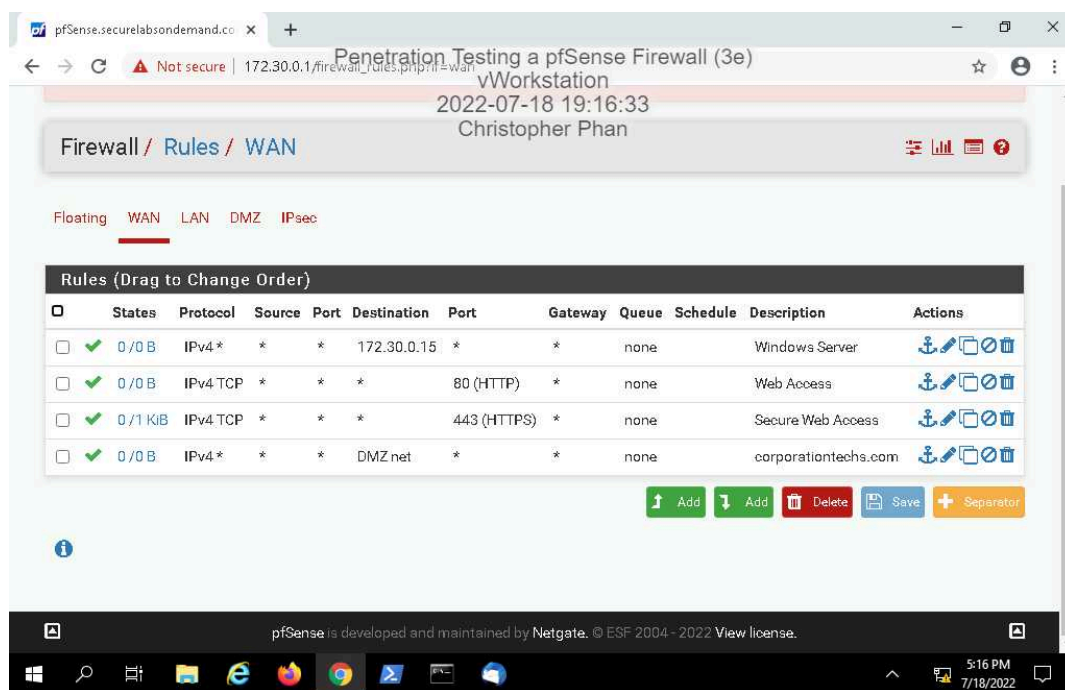
Progress:
100%

Report Generated: Wednesday, August 3, 2022 at 9:16 AM

Section 1: Hands-On Demonstration

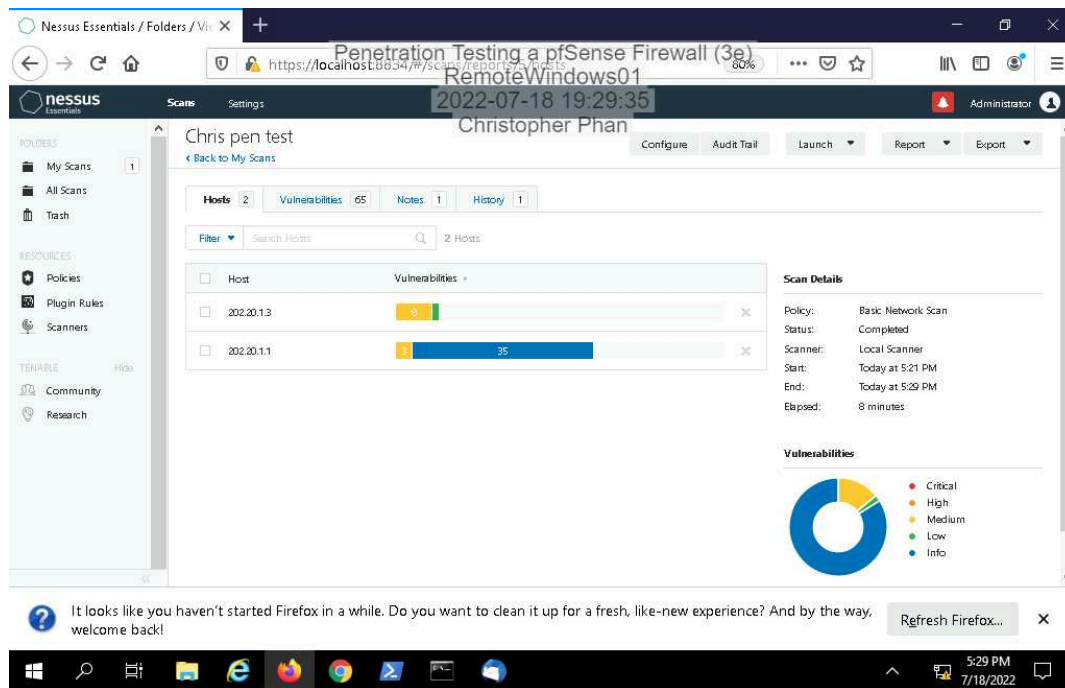
Part 1: Examine a pfSense Firewall Configuration

12. Make a screen capture showing the **WAN rules table**.

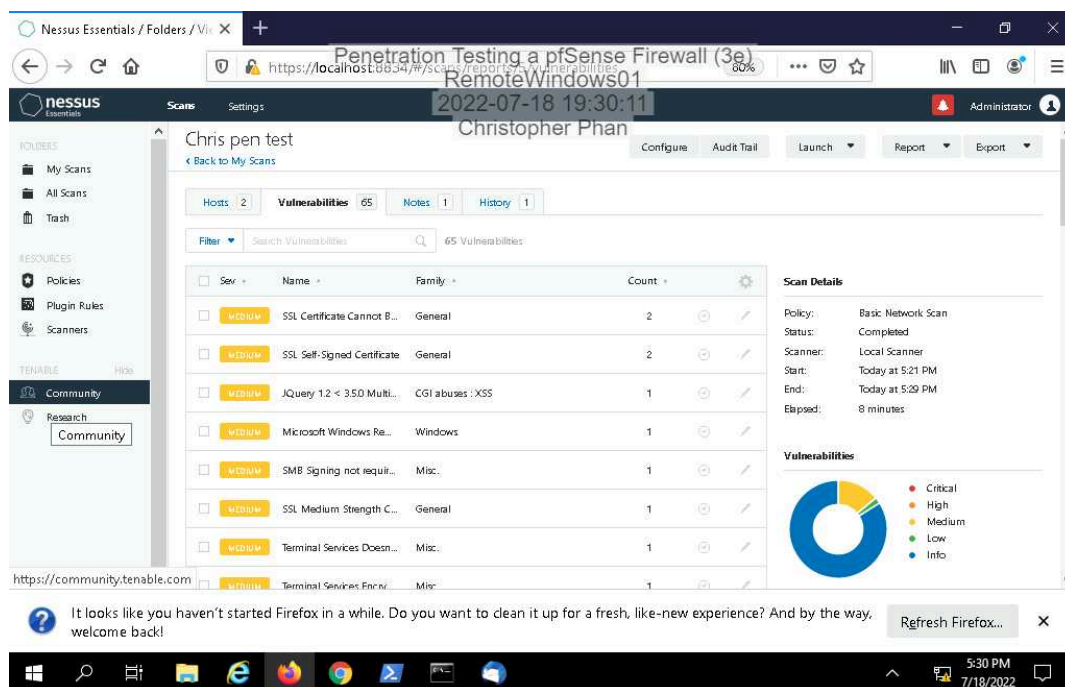


Part 2: Conduct a Penetration Test on the Network

11. Make a screen capture showing the *yourname* pen test scan results.



13. Make a screen capture showing the list of vulnerabilities.



29. Make a screen capture showing the **updated vulnerability report summary**.

The screenshot displays the Nessus Essentials web interface. The browser address bar shows the URL `https://localhost:8834/#/scans/reports/vulnerabilities`. The interface is titled "Chris pen test" and shows a summary of 34 vulnerabilities. The left sidebar contains navigation options like "My Scans", "All Scans", "Policies", "Plugin Rules", "Scanners", "Community", and "Research". The main content area features a table of vulnerabilities with columns for severity, name, family, and count. A "Scan Details" panel on the right provides information about the scan policy, status, scanner, and timing. A "Vulnerabilities" donut chart is also present, showing the distribution of vulnerability severity levels.

Sev	Name	Family	Count
CRITICAL	JQuery 1.2 < 3.5.0 Multi...	CGI abuses : XSS	1
CRITICAL	SSL Certificate Cannot B...	General	1
CRITICAL	SSL Self-Signed Certificate	General	1
INFO	Service Detection	Service detection	4
INFO	HTTP Server Type and V...	Web Servers	3
INFO	HyperText Transfer Pict...	Web Servers	3
INFO	Nessus SYN scanner	Port scanners	3
INFO	Common Platform Enu...	General	2
INFO	Device Type	General	2

Scan Details

- Policy: Basic Network Scan
- Status: Completed
- Scanner: Local Scanner
- Start: Today at 5:56 PM
- End: Today at 6:03 PM
- Elapsed: 8 minutes

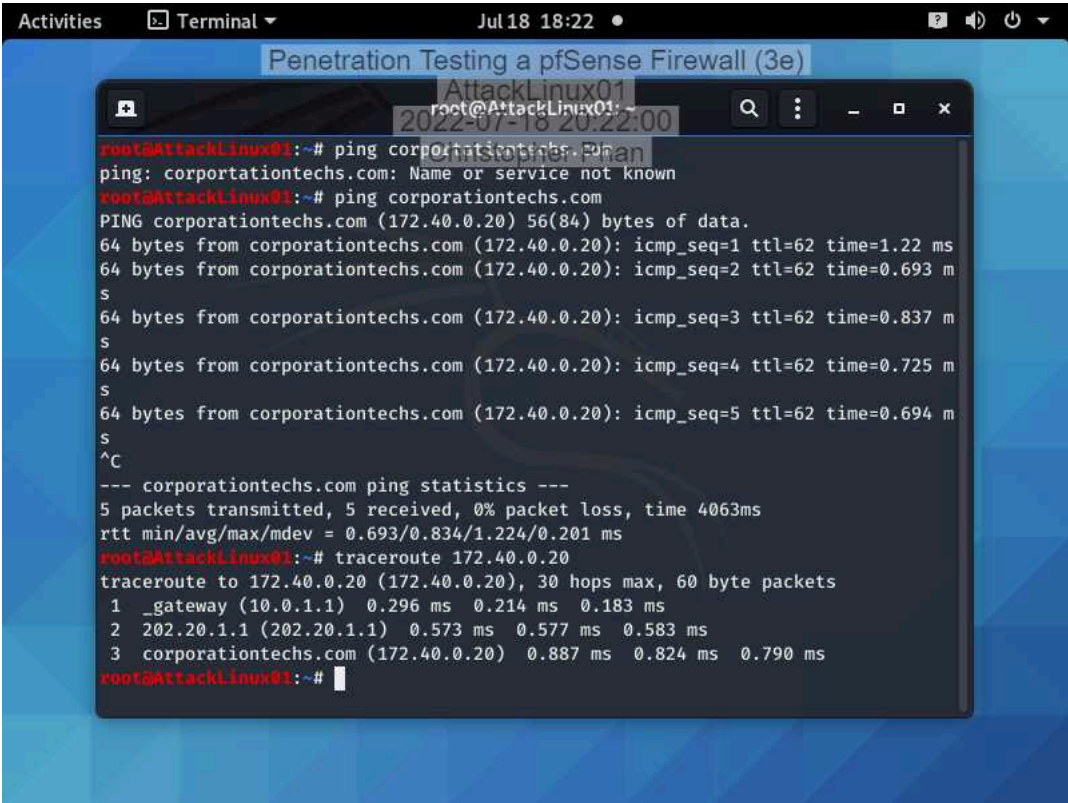
Vulnerabilities

- Critical
- High
- Medium
- Low
- Info

Section 2: Applied Learning

Part 1: Conduct a Port Scan on the Network

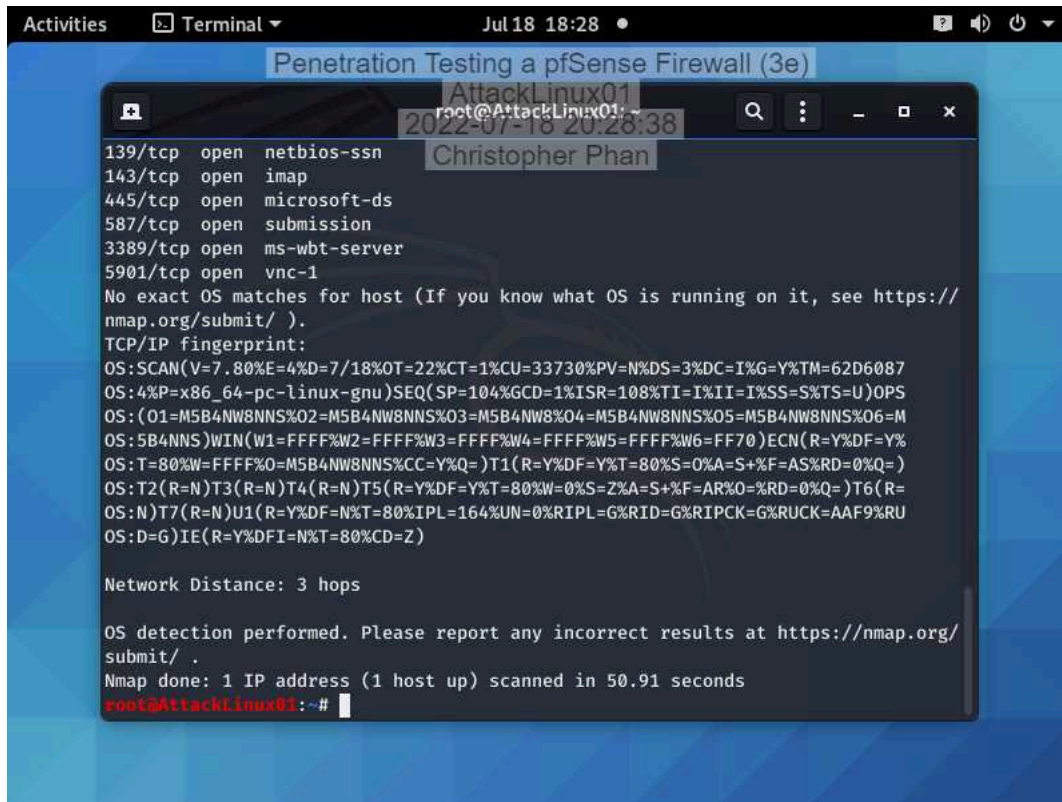
7. Make a screen capture showing the results of the traceroute command.



The screenshot shows a terminal window titled "Penetration Testing a pfSense Firewall (3e)" with a dark background. The terminal output shows a ping command to corporationtechs.com failing with "Name or service not known". A second ping command succeeds, showing 56(84) bytes of data and five successful responses with varying times. The user then presses Ctrl-C (^C) to stop the ping. Ping statistics are displayed, showing 5 packets transmitted, 5 received, and 0% packet loss. Finally, the user runs the traceroute command to 172.40.0.20, which shows three hops: the gateway (10.0.1.1), an intermediate IP (202.20.1.1), and the destination (172.40.0.20).

```
root@AttackLinux01:~# ping corporationtechs.com
ping: corporationtechs.com: Name or service not known
root@AttackLinux01:~# ping corporationtechs.com
PING corporationtechs.com (172.40.0.20) 56(84) bytes of data.
64 bytes from corporationtechs.com (172.40.0.20): icmp_seq=1 ttl=62 time=1.22 ms
64 bytes from corporationtechs.com (172.40.0.20): icmp_seq=2 ttl=62 time=0.693 ms
64 bytes from corporationtechs.com (172.40.0.20): icmp_seq=3 ttl=62 time=0.837 ms
64 bytes from corporationtechs.com (172.40.0.20): icmp_seq=4 ttl=62 time=0.725 ms
64 bytes from corporationtechs.com (172.40.0.20): icmp_seq=5 ttl=62 time=0.694 ms
^C
--- corporationtechs.com ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4063ms
rtt min/avg/max/mdev = 0.693/0.834/1.224/0.201 ms
root@AttackLinux01:~# traceroute 172.40.0.20
traceroute to 172.40.0.20 (172.40.0.20), 30 hops max, 60 byte packets
 1 _gateway (10.0.1.1) 0.296 ms 0.214 ms 0.183 ms
 2 202.20.1.1 (202.20.1.1) 0.573 ms 0.577 ms 0.583 ms
 3 corporationtechs.com (172.40.0.20) 0.887 ms 0.824 ms 0.790 ms
root@AttackLinux01:~#
```

11. Make a screen capture showing the result of the nmap scan with OS detection activated.



```
Activities  Terminal  Jul 18 18:28  Penetration Testing a pfSense Firewall (3e)
root@AttackLinux01:~# nmap -sO 10.10.10.10
2022-07-18 20:28:38
Christopher Phan

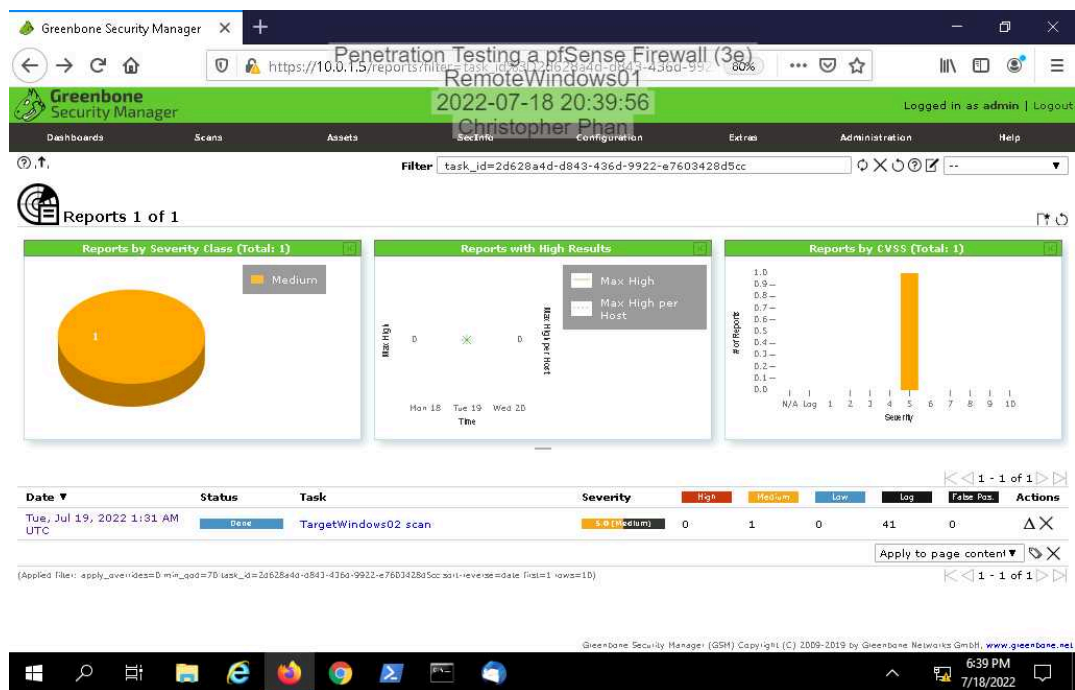
139/tcp open  netbios-ssn
143/tcp open  imap
445/tcp open  microsoft-ds
587/tcp open  submission
3389/tcp open  ms-wbt-server
5901/tcp open  vnc-1
No exact OS matches for host (If you know what OS is running on it, see https://
nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.80%E=4%D=7/18%OT=22%CT=1%CU=33730%PV=N%DS=3%DC=I%G=Y%TM=62D6087
OS:4%P=x86_64-pc-linux-gnu)SEQ(SP=104%GCD=1%ISR=108%TI=I%II=I%SS=S%TS=U)OPS
OS:(O1=M5B4NW8NNS%O2=M5B4NW8NNS%O3=M5B4NW8%O4=M5B4NW8NNS%O5=M5B4NW8NNS%O6=M
OS:5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70)ECN(R=Y%DF=Y%
OS:T=80%W=FFFF%O=M5B4NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+%F=AS%RD=0%Q=)
OS:T2(R=N)T3(R=N)T4(R=N)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=
OS:N)T7(R=N)U1(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=AAF9%RU
OS:D=G)IE(R=Y%DFI=N%T=80%CD=Z)

Network Distance: 3 hops

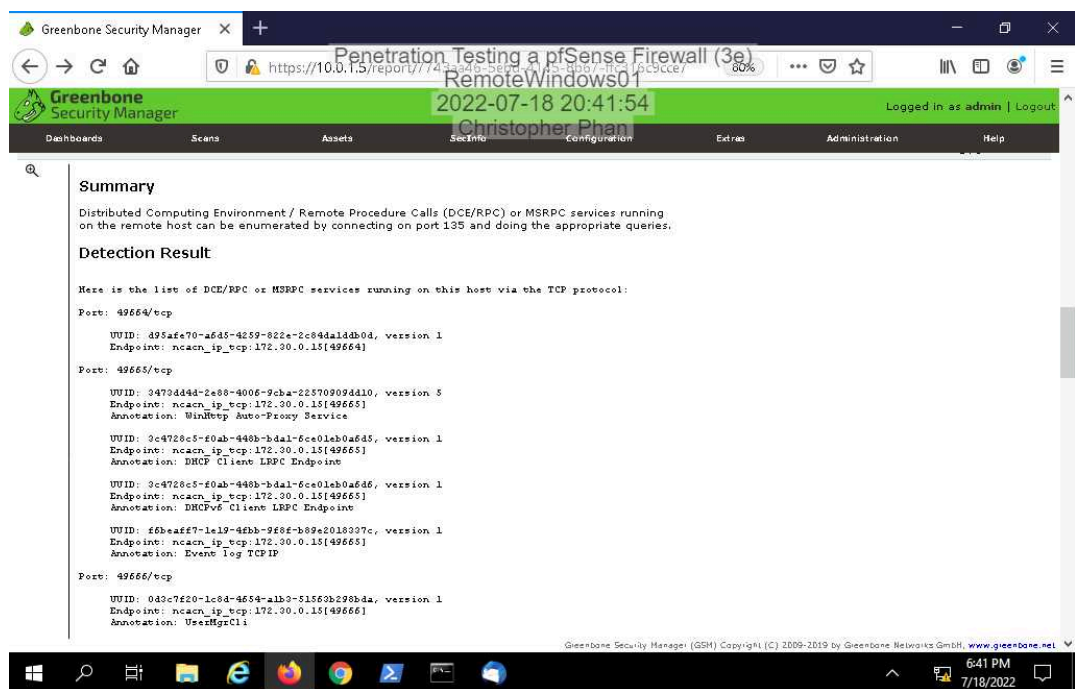
OS detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 50.91 seconds
root@AttackLinux01:~#
```

Part 2: Conduct a Vulnerability Scan on the Network

12. Make a screen capture showing the OpenVAS scan report.



14. Make a screen capture showing the detailed OpenVAS scan results.



Section 3: Challenge and Analysis

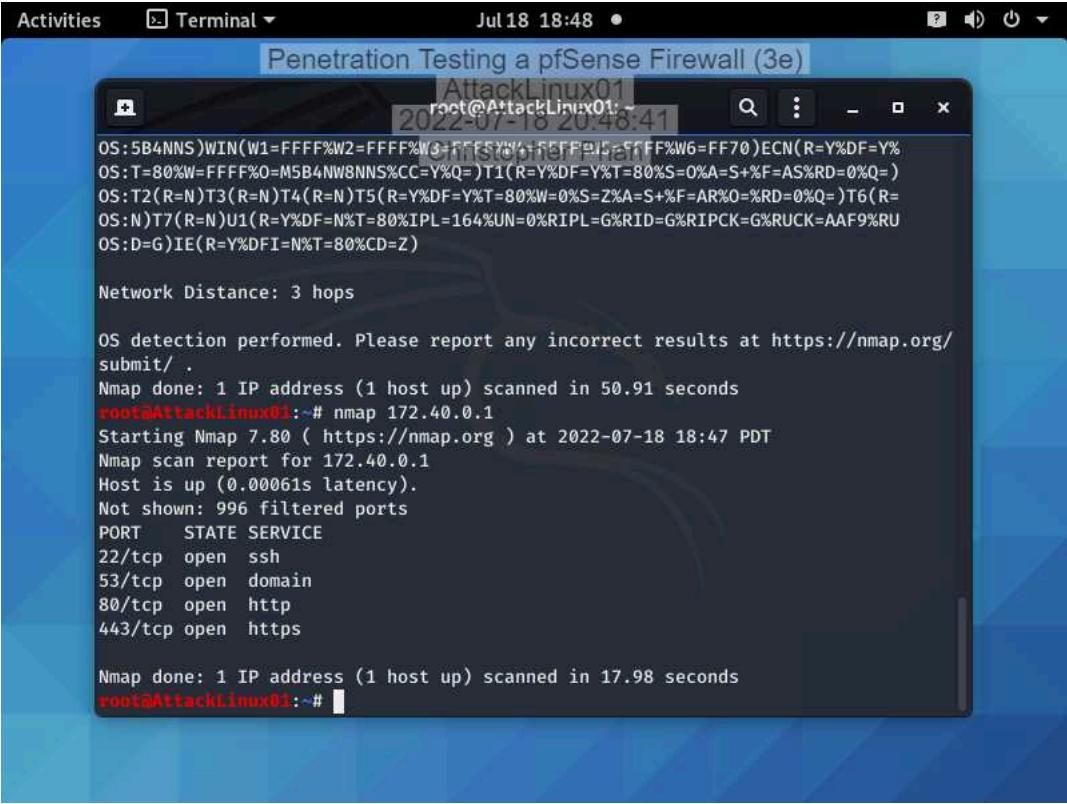
Part 1: Research DMZ Deployment Best Practices

Before beginning the technical portion of your penetration test, you decide to spend some time brushing up on best practices and common mistakes for DMZ deployments - both the network aspect and the servers located therein. Use the Internet to **research** DMZ deployments, then **identify** three best practices and one potential mistake or vulnerability.

The three best practices for DMZ deployment: (1) truly separate the DMZ from the LAN, such as establishing different IP routing and security policies for the DMZ than what is for the LAN, (2) use a two-firewall approach, in that the first firewall is an outer perimeter, sending traffic automatically to the DMZ, and from a second firewall, sending authorized traffic to the internal network, and (3) implementing a zero trust network access, forcing all users to authenticate, and deny everybody who can not authenticate. A common mistake that DMZ deployments usually have is not proper segmentation of the network, allowing unauthorized users to access the internal network.

Part 2: Conduct a Penetration Test on the DMZ

Make a screen capture showing the open ports on TargetLinux01 and the DMZ firewall interface.



The screenshot shows a terminal window titled "Penetration Testing a pfSense Firewall (3e)" with a subtitle "AttackLinux01". The terminal displays the output of an Nmap scan performed on 172.40.0.1. The scan results show four open ports: 22/tcp (ssh), 53/tcp (domain), 80/tcp (http), and 443/tcp (https). The terminal text is as follows:

```
OS:5B4NNS)WIN(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70)ECN(R=Y%DF=Y%
OS:T=80%W=FFFF%O=M5B4NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+%F=AS%RD=0%Q=)
OS:T2(R=N)T3(R=N)T4(R=N)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=
OS:N)T7(R=N)U1(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=AAF9%RU
OS:D=G)IE(R=Y%DFI=N%T=80%CD=Z)

Network Distance: 3 hops

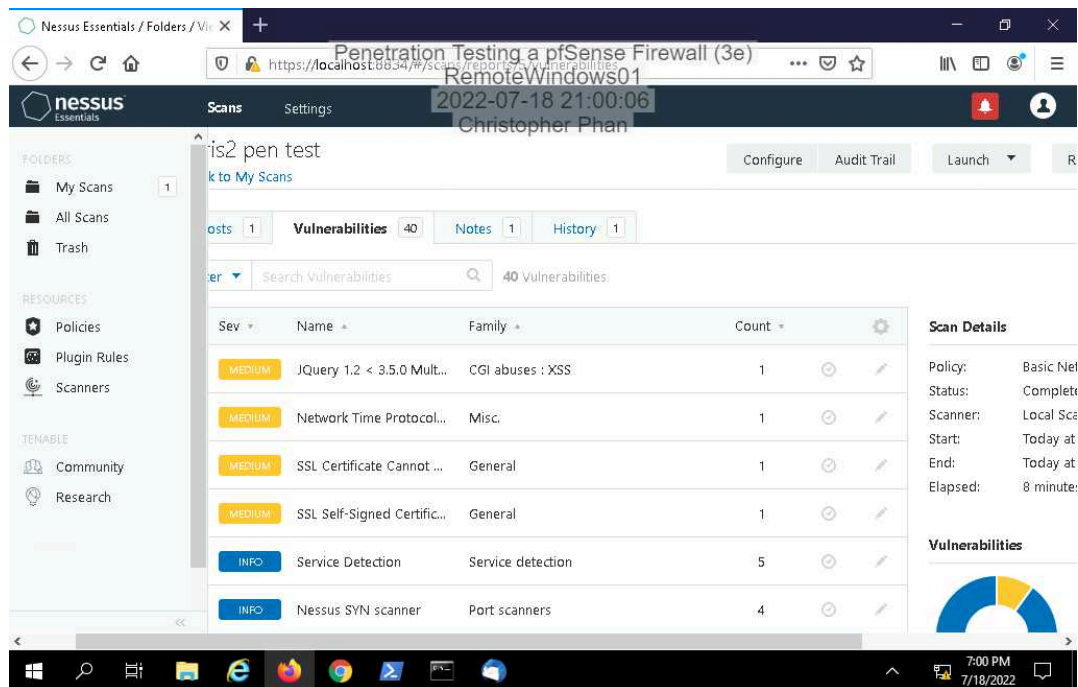
OS detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 50.91 seconds
root@AttackLinux01:~# nmap 172.40.0.1
Starting Nmap 7.80 ( https://nmap.org ) at 2022-07-18 18:47 PDT
Nmap scan report for 172.40.0.1
Host is up (0.00061s latency).
Not shown: 996 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 17.98 seconds
root@AttackLinux01:~#
```

Penetration Testing a pfSense Firewall (3e)

Network Security, Firewalls, and VPNs, Third Edition - Lab 10

Make a screen capture showing the **vulnerability scan results**.



Part 3: Recommend Changes to the DMZ

Based on your research in Part 1 and your findings in Part 2, **prepare a brief summary** of recommended changes that Secure Labs on Demand should make to their DMZ deployment. Remember, your recommendations should apply to both the network configuration and the web server.

Based on the vulnerabilities found through Nessus, 3 solutions will need to be implemented to secure the DMZ: (1) Upgrade the JQuery version to 3.5.0 or later, (2) Restricting NTP mode 6 queries, (3) Generating a proper SSL certificate.